

Drata Incident Response Plan

Date: 06/03/2025

Prepared by: Johanna Kougbéadjó

CMAP 660

1. Overview

This Incident Response Plan (IRP) defines Drata's formalized and operationally integrated process for detecting, analyzing, responding to, and recovering from cybersecurity incidents across its technical and organizational landscape. As a SaaS provider trusted by customers to automate compliance with standards like SOC 2, ISO/IEC 27001, HIPAA, and GDPR, Drata manages high volumes of sensitive data, ranging from audit artifacts to third-party integrations and identity-related telemetry. A compromise of this information could impact customer trust, legal standing, and service availability. The IRP is a critical component of Drata's operational resilience, spanning production systems, support environments, internal administrative tooling, and connected third-party platforms. It establishes a repeatable and metrics-driven response capability grounded in industry frameworks and real-world risk scenarios (Cichonski et al., 2012; NIST, 2024).

1.1 Purpose

The purpose of this IRP is to provide Drata with a battle-tested, scalable framework for incident response that ensures a coordinated, timely, and thorough handling of cybersecurity events. This plan enables the organization to detect threats early, assess their impact swiftly, contain potential spread, execute effective remediation, and restore normal operations with minimal disruption. By embedding best practices from the NIST SP 800-61r2 framework and aligning with regulatory mandates such as ISO/IEC 27001, SOC 2, and GDPR, the IRP safeguards Drata's service continuity and legal posture. Furthermore, it fosters a culture of operational resilience through a repeatable, auditable incident response process that is consistent across systems, teams, and third-party dependencies (Kok-Boon Oh et al., 2022).

2. System Description

Drata's technical infrastructure is architected as a cloud-native, multi-tenant SaaS platform hosted entirely on Amazon Web Services (AWS). It employs a service-oriented architecture built with containerized microservices managed via Kubernetes, and secure RESTful APIs that facilitate integration with key external systems such as GitHub, Google Workspace, Azure AD, and AWS accounts. These integrations power Drata's real-time evidence collection, continuous control monitoring, and automated compliance tracking features.

User interaction with the platform occurs through a secure web interface, protected by enforced HTTPS, multi-factor authentication, session management policies, and role-based access control (RBAC). Data is encrypted using AES-256 encryption both at rest and in transit via TLS 1.2 or higher. All application activity is centrally logged and monitored.

The platform is designed for high availability and resilience, leveraging AWS multi-AZ deployment, automated failover, and multi-region redundancy. Encrypted backups are generated daily and stored with immutable retention policies in isolated storage buckets. Drata maintains active partnerships with leading cybersecurity firms, managed detection and response (MDR)

providers, and cloud infrastructure vendors to support continuous security operations and 24/7 incident response capability.

This robust and extensible infrastructure underpins Drata's ability to deliver secure, scalable, and regulatory-compliant services to a global customer base while remaining responsive to evolving threat landscapes and customer needs.

3. Roles and Responsibilities

Drata's Incident Response Team (IRT) is a multidisciplinary team composed of key personnel from across the organization, selected for their operational roles and subject matter expertise in handling security incidents. The IRT is responsible for executing this plan from initial detection through containment, recovery, and post-incident analysis. Members are on-call during business and non-business hours according to an established roster and escalation procedure (Cichonski et al., 2012).

The Incident Response Manager (IRM) serves as the operational lead for all incident response activities, coordinating communication, decision-making, and documentation. The Chief Information Security Officer (CISO) provides executive oversight, ensuring alignment between the IRP and Drata's broader risk management and governance frameworks. The Security Operations Center (SOC) monitors telemetry, alerts, and logs 24/7 to detect and triage anomalous activity. Engineering and DevOps teams isolate compromised components, deploy containment strategies, assist with root cause eradication, and restore services. Legal and Compliance oversee all regulatory and contractual reporting obligations, ensuring incidents are handled in a legally defensible manner and documented for audit purposes. The Communications function drafts and delivers incident-related updates to internal stakeholders, customers, and, when necessary, the media. Human Resources intervenes in cases involving insider threats, compromised credentials, or privacy breaches affecting employees.

To ensure responsiveness and reduce ambiguity, each functional area has named primary and secondary representatives with defined roles and responsibilities. Contact directories, communication templates, and escalation matrices are maintained as part of the IRP toolkit and reviewed quarterly (Cyber and Data Security Incident Response Plan Template, n.d.-a).

Role	Responsibilities
Chief Information Security Officer (CISO)	Oversees security strategy and incident response program.
Incident Response Manager (IRM)	Leads incident response operations and ensures documentation and communications.
Security Operations Center (SOC)	Monitors alerts, investigates suspicious activity, and initiates triage.
Engineering & DevOps	Assists in containment, eradication, and recovery activities.
Legal & Compliance	Ensures regulatory reporting and legal review.
Customer Success/Communications	Manages external messaging and customer communications.

4 Reporting Guidelines

All Drata personnel, including full-time employees, contractors, and third-party support staff, are obligated to report any suspected or confirmed security incidents as soon as they are identified. Timely reporting is critical for effective triage and containment. Reports must be submitted through designated and monitored communication channels, including the internal IRP Slack channel, the Jira-based incident queue, or the dedicated incident response email alias (irp@drata.com). All channels are actively monitored by the Security Operations Center (SOC). Reportable incident types include, but are not limited to, unauthorized access to production systems, suspected data exfiltration, endpoint malware infections, privilege abuse, denial-of-service attacks, phishing or spear-phishing attempts, insider threats, and any behavior indicating account compromise. Additionally, anomalies surfaced by internal logging systems or external partners (e.g., AWS GuardDuty, Snyk, or identity providers) must also be reported immediately (Uberoi, 2024).

Incident reports must be factual, time-stamped, and structured. They should include a concise summary of the event, systems or accounts involved, the method of detection, suspected threat vector, and any actions taken prior to escalation (such as password resets or temporary access revocation). The SOC will acknowledge the report within one business hour and begin triage using established playbooks. High-confidence incidents are immediately escalated to the IRT based on Drata's severity classification matrix.

5 Responding to an incident

5.1 Organization

The IRT operates under the leadership of the Incident Response Manager (IRM), with active participation from the Chief Information Security Officer (CISO), Engineering and DevOps Leads, Security Operations Center (SOC), Legal and Compliance Officers, Communications, and Human Resources. Each member has predefined responsibilities aligned with Drata's incident response playbooks, ensuring speed, clarity, and accountability during incident handling.

When an incident exceeds internal capabilities – such as in the case of a zero-day exploit, data breach with cross-border implications, or prolonged service outage – Drata escalates to trusted external partners. These may include retained digital forensics and incident response (DFIR) firms, outside legal counsel for breach notification support, cyber insurance carriers, or public relations specialists.

Incidents are triaged using Drata's internal Severity Assessment Matrix, which evaluates the scope, impact, urgency, regulatory exposure, and customer effect. Escalation levels range from internal-only coordination to full-scale executive war room activation. Each severity level has defined response timelines, communication protocols, and audit trail requirements that align with NIST SP 800-61r2 and ISO/IEC 27035 best practices (NIST, 2024).

5.2 Incident Response

Cyber incident response management is a continuous and iterative process. The key components of the Cyber Incident Response Plan are as follows (Cichonski et al., 2012):



Source: <https://wirexsystems.com/resource/sans-incident-response-framework/>

The incident response process follows the NIST framework and consists of several stages that ensure a structured approach to managing and mitigating incidents:

- 1) Preparation:** Data ensures readiness through quarterly phishing simulations, red team exercises, and IRP reviews. Technical staff receive specialized incident response training. Preventive controls, logging, and detection tools are regularly assessed (Amoo et al., 2024).
- 2) Identification:** The SOC reviews automated alerts, behavioral logs, and user-reported anomalies to determine if a cybersecurity event constitutes an incident. Initial classification, scoping, and prioritization are performed.
- 3) Containment:** Affected systems or accounts are isolated to prevent further impact. Network filtering, identity management, and access revocation are applied where needed. Systems are preserved for forensic review. Coordination with third-party security vendors and regulators may occur at this stage, in line with intelligence-sharing protocols (Uberoi, 2024).
- 4) Eradication:** Malicious code, unauthorized users, and compromised assets are removed. Engineering and SOC coordinate patching, cleansing, and updating defensive controls. Forensic analysis is often conducted to understand how the breach occurred and to prevent recurrence (Cichonski et al., 2012).

5) Recovery: Clean systems are restored and revalidated before rejoining production. Monitoring is intensified to detect potential recurrence. Communications to affected parties may include updates or remediation services such as credit monitoring. Restoration efforts prioritize operational continuity, customer confidence, and regulatory compliance (PCI SSC, 2024).

6) Follow-up: A comprehensive root cause analysis is conducted, and findings are documented in a post-incident report. The IRT holds a retrospective to review response effectiveness, identify gaps, and implement recommended changes to the IRP, playbooks, and associated controls (Kok-Boon Oh et al., 2022).

6 Training and Exercise

All Drata personnel receive cybersecurity onboarding during their initial employment, followed by mandatory annual refresher training that incorporates recent threat trends, policy changes, and incident case studies. For technical staff – such as engineers, SOC analysts, and site reliability engineers – quarterly training focuses on advanced topics including log analysis, threat detection, and containment tactics aligned with real-world attack scenarios. These trainings are designed in collaboration with external threat intelligence partners to reflect the latest adversary tactics, techniques, and procedures (TTPs).

To validate preparedness, Drata conducts a multi-layered exercise program that includes quarterly tabletop simulations tailored to Drata’s current threat landscape and annual red team engagements conducted by external penetration testing firms. These exercises simulate real-world attacks, including zero-day exploit attempts, credential theft, and insider threats, and test the organization’s detection and response efficacy under time pressure.

Outcomes from these exercises are meticulously documented, with actionable findings shared with executive sponsors. Identified gaps feed into a formal continuous improvement loop that updates playbooks, training content, and technical defenses. Metrics such as time-to-detection, containment efficiency, and inter-team coordination effectiveness are tracked longitudinally to assess maturity growth over time (Amoo et al., 2024; Cichonski et al., 2012).

7 Lessons Learned

Drata formalizes the conclusion of every significant security incident through a comprehensive after-action review (AAR), documented in a standardized post-incident report. This report includes a detailed incident chronology, impact assessment, root cause analysis, stakeholder communications log, containment and remediation effectiveness, and clearly defined corrective and preventive actions (CAPAs). Where applicable, the IRT also includes quantitative metrics such as mean time to detect (MTTD), mean time to contain (MTTC), and mean time to recover (MTTR) to support continuous program improvement.

Lessons learned are reviewed in a structured debrief with executive leadership and risk governance stakeholders, where they are prioritized for follow-up and formally assigned through

Drata's risk management system. Updates resulting from incident reviews may trigger changes to technical controls, process documentation, employee training programs, third-party risk monitoring procedures, or customer communications workflows. These lessons are not only operationally implemented but also audited as part of quarterly IRP reviews to ensure accountability and closure.

This feedback loop enables Drata to transform reactive experiences into proactive improvements – hardening defenses, improving readiness, and maturing incident response capabilities over time (Kok-Boon Oh et al., 2022; Amoo et al., 2024).

References

- Amoo, O., Abrahams, T., Farayola, O., Amoo, O., Ayinla, B., Osasona, F., & Atadoga, A. (2024). *Continuous improvement in information security: A review of lessons from superannuation cybersecurity uplift programs*. International Journal of Science and Research Archive, 11, 1327–1337. <https://www.researchgate.net/publication/378105766>
- California Consumer Privacy Act. (2018). https://coppa.ca.gov/regulations/pdf/coppa_act.pdf
- Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012, August). *Computer Security Incident Handling Guide* (NIST SP 800-61 Revision 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>
- Cyber and Data Security Incident Response Plan Template. (n.d.-a). <https://cdn.fedweb.org/fed-34/2/Cyber-Security-Incident-Response-Template.pdf>
- Kok-Boon Oh, B., Ho, B., & Slade, B. (2022). *Cybersecurity Risk Management: An ERM Approach*. Nova Science Publishers.
- Montag, G. (2023, February 7). *SANS Incident Response Framework*. WireX. <https://wirexsystems.com/resource/sans-incident-response-framework/>
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. <https://doi.org/10.6028/NIST.CSWP.29>
- PCI Security Standards Council. (2024). *Payment Card Industry Data Security Standard: Requirements and Testing Procedures*, v4.0.1. https://www.commerce.uwo.ca/pdf/PCI-DSS-v4_0.pdf
- Uberoi, A. (2024). *Cyber Crisis Communications: How to Communicate During a Cyber Attack?*. Cybersecurity Management Alliance. <https://www.cm-alliance.com/cybersecurity-blog/cyber-crisis-communications-how-to-communicate-during-a-cyber-attack>